

La sécurité des accès distants et des équipements de bordure

Du VPN au Zero Trust. Veille suivie sur 11 mois, décembre 2025 – octobre 2026.

Dernière entrée : Octobre 2026 · mise à jour chaque mercredi, environ 20 minutes

15 cas d'exploitation	9 éditeurs touchés
11 mois couverts	20 vulnérabilités suivies
11/15 exploités avant le correctif	

Le sujet

Une entreprise doit être joignable depuis Internet : ses salariés se connectent à distance, ses sites communiquent entre eux. Elle installe donc à sa frontière des **équipements de bordure** — pare-feu, concentrateurs VPN, passerelles d'accès.

Ces équipements sont visibles du monde entier, disposent d'un accès privilégié au réseau interne et sont difficiles à arrêter pour être mis à jour. Dans son Panorama de la cybermenace 2024, l'ANSSI indique que **plus de la moitié de ses opérations de cyberdéfense** — son plus haut niveau d'engagement en réponse à incident — ont eu pour origine l'exploitation de vulnérabilités sur ces équipements. L'édition 2025 confirme que ces vulnérabilités peuvent être exploitées très vite après leur publication.

RÉFÉRENCE

ANSSI, *Panorama de la cybermenace 2024* <<https://cyber.gouv.fr/publications/panorama-de-la-cybermenace-2024>>

mars 2025

Pourquoi ce sujet

- Il recouvre ce que j'administre en SISR : VPN, pare-feu, règles de filtrage, certificats, annuaire.
- Il est d'actualité en continu : sur les 11 mois observés, aucun ne s'est écoulé sans une vulnérabilité exploitée sur ce type d'équipement.
- Il rejoint mon projet professionnel, orienté vers la sécurité des infrastructures et du cloud.

Le périmètre

RETENU les vulnérabilités activement exploitées qui touchent les pare-feu, les passerelles VPN et d'accès distant, le SD-WAN et les serveurs qui pilotent l'accès distant, ainsi que les décisions des autorités (ANSSI, CISA) sur ces équipements.

ÉCARTÉ ce qui ne concerne pas l'accès au réseau, même lorsque le CERT-FR en fait une alerte. Sur la période, j'ai ainsi laissé de côté les alertes sur le ciblage des messageries instantanées (20 mars 2026), WordPress (20 juillet 2026) et Metabase (10 septembre 2026).

Dispositif de veille

Ma veille repose sur des sources classées par rôle, toutes suivies par flux RSS dans un agrégateur.

COUCHE	SOURCE	RÔLE
DATATION	CERT-FR (alertes, avis, bulletins d'actualité), CERT Santé, Centre canadien pour la cybersécurité	Établit le fait et sa date. Officiel, archivé.
DATATION CROISÉE	CISA — catalogue KEV	Confirme l'exploitation active, avec date d'ajout et échéance de correction.
EXPLICATION	LeMagIT, IT Social, ITdaily (FR) ; BleepingComputer, The Hacker News, Help Net Security (EN)	Contexte, portée pour les entreprises, rapidité.
ANALYSE TECHNIQUE	Rapid7, Volexity, Unit 42, GreyNoise, Arctic Wolf	Mécanisme d'exploitation, chaîne d'attaque, date réelle de la première exploitation.
RÉFÉRENCE	ANSSI (panoramas annuels, guides)	Recul sur l'année et recommandations.
AGRÉGATION	Feedly (flux RSS de tout ce qui précède)	Un seul point d'entrée, consulté chaque semaine (environ 20 minutes).

Trois règles de méthode

1. **Croiser au moins deux couches par fait.** Une alerte seule dit quoi et quand ; il faut une seconde source pour dire comment et pourquoi ça compte.
2. **Dater sur la première version.** Les listes du CERT-FR affichent la date de dernière mise à jour d'un bulletin, parfois postérieure de plusieurs mois. Je retiens la « date de la première version » indiquée dans chaque bulletin.
3. **Séparer les faits de mon analyse.** Dans la chronologie, chaque source porte l'étiquette de sa couche ; mes commentaires sont signalés par l'étiquette « mon analyse ».

La première règle est vérifiée par le site lui-même : une entrée dont toutes les sources appartiennent à la même couche fait échouer la compilation.

Vue d'ensemble

MOIS	PRODUIT	FAIT MARQUANT	EXPLOITATION
Déc. 2025	WatchGuard Firebox	Exécution de code via le VPN IKEv2	Avant correctif
Janv. 2026	Ivanti EPMM	Deux exécutions de code sans authentification	Avant correctif
Févr. 2026	Cisco Catalyst SD-WAN	Contournement d'authentification, CVSS 10	Avant correctif
Mars 2026	F5 BIG-IP APM	Exécution de code, faille corrigée en octobre 2025	Après correctif
Avr. 2026	Fortinet FortiClient EMS	Exécution de code sans authentification	Avant correctif
Mai 2026	Palo Alto PAN-OS (portail captif), Palo Alto GlobalProtect	Zero-day du portail captif, puis contournement d'authentification du VPN	Avant et après correctif
Juin 2026	Check Point VPN	Contournement d'authentification, rançongiciel Qilin	Avant correctif
Juill. 2026	SonicWall SMA 1000	Chaîne de deux failles jusqu'aux droits root	Avant correctif
Août 2026	Citrix NetScaler	« Déni de service » devenu exécution de code	Après correctif
Sept. 2026	SonicWall SMA 1000, Check Point VPN, F5 BIG-IP APM, Citrix NetScaler	Quatre éditeurs touchés dans le mois	Avant et après correctif
Oct. 2026	Citrix NetScaler	Déni de service via le traitement SAML	Avant correctif

Chronologie

Une entrée par mois, de la plus récente à la plus ancienne. Chaque source porte l'étiquette de sa couche ; mon commentaire est signalé séparément.

DATATION

CERT-FR, *CERTFR-2026-ALE-011, mise à jour* <<https://www.cert.ssi.gouv.fr/alerte/CERTFR-2026-ALE-011/>>

5 octobre 2026

EXPLICATION

LeMagIT, Citrix Netscaler : deux vulnérabilités utilisées pour déployer des têtes de pont <<https://www.lemagit.fr/actualites/366651421/Citrix-Netscaler-deux-vulnerabilites-utilisees-pour-deployer-des-tetes-de-pont>>

1er octobre 2026

EXPLICATION

The Hacker News, New NetScaler Zero-Day Exploited in Targeted Attacks Can Knock SAML Deployments Offline <<https://thehackernews.com/2026/10/new-netscaler-zero-day-exploited-in.html>>

octobre 2026

CVE-2026-88779

CVSS 8.7

- Retour sur les failles de septembre (LeMagIT, 1^{er} octobre) : selon Mandiant, la campagne d'exploitation a débuté au moins début septembre, avec dépôt de webshells puis utilisation d'un tunnel vers le réseau interne pour la reconnaissance et le vol d'identifiants
- Mandiant souligne que ces équipements, exposés à Internet, sont hors de portée des outils de détection installés sur les postes (EDR) ; Citrix recommande de transférer leurs journaux vers une plateforme externe
- CVE-2026-88779 (CVSS 8.7) : dépassement mémoire dans le traitement SAML → déni de service à distance
- Concerne les NetScaler configurés comme fournisseur de services ou fournisseur d'identité SAML
- Divulguée le 4 octobre 2026, déjà exploitée ; ajout au catalogue KEV le même jour
- Selon Rapid7, chaque tentative fait tomber le service SAML et, à la sixième, l'équipement redémarre

Mon analyse. SAML est le protocole d'authentification unique : c'est par lui que passent les connexions des utilisateurs. L'impact confirmé ici n'est pas une intrusion mais une indisponibilité : en faisant tomber le traitement de l'authentification, l'attaquant coupe l'accès distant de toute l'organisation. Cela

rappelle que la sécurité d'une passerelle se juge sur trois critères, la disponibilité autant que la confidentialité et l'intégrité. Le bilan de Mandiant ajoute une raison de fond au succès de ces attaques : une passerelle ne peut pas recevoir d'agent de détection comme un poste de travail. La seule visibilité vient de ses journaux, à condition qu'ils soient envoyés ailleurs.

Chronologie arrêtée au 7 octobre 2026 ; la veille se poursuit.

DATATION

CERT-FR, CERTFR-2026-ALE-009 — Multiples vulnérabilités dans SonicWall Secure Mobile Access <<https://www.cert.ssi.gouv.fr/alerte/CERTFR-2026-ALE-009/>>

2 septembre 2026

EXPLICATION

ITdaily, Check Point VPN contient des vulnérabilités critiques <<https://itdaily.fr/nouvelles/securite/check-point-vpn-presente-des-vulnerabilites-critiques/>>

14 septembre 2026

EXPLICATION

BleepingComputer, Check Point warns of hackers exploiting Security Gateway VPN RCE flaw <<https://www.bleepingcomputer.com/news/security/check-point-warns-of-hackers-exploiting-security-gateway-vpn-rce-flaw/>>

23 septembre 2026

DATATION

Centre canadien pour la cybersécurité, Alerte AL26-022 – Vulnérabilité touchant F5 BIG-IP Access Policy Manager (APM) <<https://www.cyber.gc.ca/fr/alertes-avis/al26-022-vulnerabilite-touchant-f5-big-ip-access-policy-manager-apm-cve-2026-94127>>

22 septembre 2026

EXPLICATION

ITdaily, F5 alerte sur une faille activement exploitée dans BIG-IP APM <<https://itdaily.fr/nouvelles/reseau/f5-big-ip-apm-bug-cve-2026-94127/>>

septembre 2026

DATATION

CERT-FR, CERTFR-2026-ALE-011 — Multiples vulnérabilités dans Citrix NetScaler ADC et Gateway <<https://www.cert.ssi.gouv.fr/alerte/CERTFR-2026-ALE-011/>>

28 septembre 2026

EXPLICATION

LeMagIT, Citrix Netscaler : il est plus que temps d'appliquer les patches <<https://www.lemagit.fr/news/366651335/Citrix-Netscaler-il-est-plus-que-temps-dappliquer-les-patches>>

septembre 2026

ANALYSE TECHNIQUE

Rapid7, Zero-Day Exploitation of Citrix NetScaler ADC and Gateway <<https://www.rapid7.com/blog/post/etr-zero-day-exploitation-of-citrix-netscaler-adc-and-gateway-cve-2026-88771-and-cve-2026-88772/>>

28 septembre 2026

ANALYSE TECHNIQUE

GreyNoise, GreyNoise Timeline: Citrix CVE-2026-88771 <<https://www.greynoise.io/chronicle/gntl-20260928-citrix-cve-2026-88771>>

28 septembre 2026

ANALYSE TECHNIQUE

Unit 42, Threat Brief: NetScaler Zero Days CVE-2026-88771 and CVE-2026-88772 Exploited in the Wild <<https://unit42.paloaltonetworks.com/netscaler-zero-days-exploited/>>

30 septembre 2026

CVE-2026-83548

CVE-2026-83549

CVE-2026-85102

CVE-2026-94127

CVE-2026-88771

CVE-2026-88772

CVSS 9.8

SonicWall SMA 1000 — 1^{er} septembre

- CVE-2026-83548 (SSRF sans authentification) et CVE-2026-83549 (exécution de code avec les droits administrateur), toutes deux exploitées
- Même produit, mêmes modèles et même schéma qu'en juillet ; là encore, le correctif seul ne suffit pas

Check Point VPN — 9 septembre

- CVE-2026-85102 (CVSS 9.8) : validation défaillante des certificats pendant la négociation VPN → exécution de code sans authentification sur la passerelle
- Correctif publié le 9 septembre ; attaques observées dès le 12 septembre, trois jours plus tard ; exploitation confirmée par l'éditeur le 22 septembre
- Ajout au catalogue KEV le 22 septembre, correction exigée pour le 25

F5 BIG-IP APM — 22 septembre

- CVE-2026-94127 : dépassement de tampon permettant une exécution de code sans authentification, déjà exploité à la publication
- Concerne les systèmes qui combinent une politique d'accès APM et un profil OAuth

Citrix NetScaler — 27 septembre

- Huit vulnérabilités, dont CVE-2026-88771 (exécution de code en configuration par défaut) et CVE-2026-88772 (exécution de code lorsque DTLS est activé), exploitées avant la disponibilité des correctifs
- Selon Rapid7, l'attaquant archive la configuration de l'équipement (mots de passe chiffrés, clés privées des certificats) dans un dossier que la passerelle sert publiquement : elle devient téléchargeable sans authentification
- Selon Unit 42, la faille sert aussi à déposer un webshell, et des requêtes d'attaque sont encore relevées quelques heures avant la publication du bulletin

Date	Événement
10 septembre	Citrix réserve les identifiants CVE (relevé par GreyNoise)
20 septembre, 14 h 28 UTC	Première tentative d'exploitation observée par Rapid7
24 septembre	Tentatives d'exploitation observées par GreyNoise
27 septembre	Bulletin Citrix et correctifs ; ajout au KEV ; alerte de la CISA
28 septembre	Alerte du CERT-FR ; première preuve de concept publique
4 octobre	Nouvelle vulnérabilité exploitée (voir octobre)

Mon analyse. C'est le mois le plus chargé de la période, et il pose la question de la récurrence : les quatre produits touchés l'avaient tous déjà été plus tôt dans l'année.

Sur **SonicWall** : le même produit fait l'objet de deux alertes en sept semaines, la seconde arrivant neuf jours après la clôture de la première. Deux lectures sont possibles : soit le premier correctif était incomplet, soit le produit est devenu une cible que chercheurs et attaquants scrutent intensément. Dans les deux cas, un produit qui revient en alerte justifie une surveillance renforcée, voire une réflexion sur son remplacement.

Sur **Check Point** : ici le correctif existait, et les attaques ont commencé trois jours après sa publication. C'est la mesure du temps dont dispose réellement un administrateur pour mettre à jour une passerelle exposée.

Sur **Citrix** : la faille principale touche la configuration par défaut, donc tout déploiement non corrigé. Surtout, la configuration et les clés privées ont pu être copiées. Corriger ne suffit donc pas : il faut aussi renouveler les certificats et les mots de passe stockés sur l'équipement.

Lien avec le BTS SIO SISR : renouvellement et révocation de certificats, protection des configurations, supervision.

EXPLICATION

Help Net Security, *Previously patched Citrix NetScaler flaw exploited in the wild (CVE-2026-8452)* <<https://www.helpnetsecurity.com/2026/08/27/netscaler-adc-gateway-cve-2026-8452/>>

27 août 2026

DATATION CROISÉE

The Hacker News, *CISA Adds Six Exploited Flaws to KEV, Including NetScaler, Linux, and SQL Server Bugs* <<https://thehackernews.com/2026/08/cisa-adds-six-exploited-flaws-to-kev.html>>

27 août 2026

CVE-2026-8452

- CVE-2026-8452 : dépassement mémoire sur les NetScaler configurés en passerelle d'accès (VPN SSL, ICA Proxy) ou en serveur d'authentification
- Corrigée le 30 juin 2026, et présentée alors comme pouvant provoquer un déni de service
- Le 14 août, des chercheurs publient une analyse et une preuve de concept ; l'exploitation suit en quelques jours, avec dépôt de webshells sur les équipements
- Ajout au catalogue KEV le 26 août, correction exigée pour le 29 août
- Le 24 août, le CERT-FR clôt son alerte SonicWall de juillet

Mon analyse. Août aurait pu passer pour un mois calme. Il montre au contraire deux choses. La gravité annoncée par un éditeur peut être sous-estimée : ceux qui ont classé cette faille « simple déni de service » sont restés exposés sept semaines. Et la publication d'une preuve de concept transforme en quelques jours une faille corrigée en attaque réelle. Sur un équipement de bordure, un correctif de sécurité s'applique sans attendre, quelle que soit la gravité affichée.

Lien avec le BTS SIO SISR : politique de mise à jour, suivi des preuves de concept publiques.

DATATION

CERT-FR, *CERTFR-2026-ALE-006 — Multiples vulnérabilités dans Sonicwall Secure Mobile Access* <<https://www.cert.ssi.gouv.fr/alerte/CERTFR-2026-ALE-006/>>

15 juillet 2026

ANALYSE TECHNIQUE

Volexity, Proxying to Compromise: SonicWall Secure Mobile Access 0-day Exploitation <<https://www.volexity.com/blog/2026/07/17/proxying-to-compromise-sonicwall-secure-mobile-access-0-day-exploitation/>>

17 juillet 2026

EXPLICATION

Help Net Security, SonicWall SMA zero-days were exploited weeks before disclosure <<https://www.helpnetsecurity.com/2026/07/21/sonicwall-sma-zero-days-exploited-cve-2026-15409-cve-2026-15410/>>

21 juillet 2026

CVE-2026-15409

CVE-2026-15410

- CVE-2026-15409 (SSRF sans authentification) et CVE-2026-15410 (exécution de code avec les droits administrateur) sur les passerelles SMA 1000, modèles 6210, 7210 et 8200v
- Avis de l'éditeur le 14 juillet 2026 ; première trace de compromission relevée par Volexity le 22 juin, soit 22 jours plus tôt
- Ajout au catalogue KEV le 14 juillet, correction exigée pour le 17 juillet
- Chaîne d'attaque en trois temps :
 - contournement d'authentification par une requête forgée `GET /wsproxy?bmID=-3389...` portant l'en-tête `User-Agent: SMA Connect Agent`, qui ouvre un tunnel WebSocket vers des services normalement accessibles depuis la machine seulement ;
 - accès à la base CouchDB locale, livrée avec des identifiants codés en dur (`admin / admin`), pour déposer un script sur l'équipement ;
 - appel de `sysCtrl.execRemoveHotfix` avec une traversée de répertoire (`../../../../../../../../tmp/1234.sh`) pour exécuter ce script en root.
- Charge finale : le maliciel KNUCKLEBALL, qui injecte dans un processus légitime un proxy HTTP (Suo5) et un webshell (ORANGETAIL), puis capture du trafic LDAP non chiffré pour récupérer des identifiants. Volexity note que l'attaquant a eu moins de succès pour progresser ensuite dans le réseau

- En cas d'indices de compromission, le correctif ne suffit pas : il faut réinstaller le système, changer tous les mots de passe et réinitialiser les codes à usage unique

Mon analyse. Pendant trois semaines, les équipes qui suivaient uniquement les bulletins officiels ne pouvaient rien savoir. La chaîne technique est aussi un cas d'école aligné sur le programme : identifiants par défaut jamais changés, entrées non contrôlées, services locaux atteignables par un tunnel, annuaire interrogé en clair. Chaque étape correspond à une règle vue en cours, et le respect d'une seule aurait compliqué l'attaque.

Lien avec le BTS SIO SISR : comptes par défaut, LDAPS, segmentation, réponse à incident.

DATATION

CERT-FR, CERTFR-2026-AVI-0711 — Multiples vulnérabilités dans les VPN Check Point <<https://www.cert.ssi.gouv.fr/avis/CERTFR-2026-AVI-0711/>>

9 juin 2026

EXPLICATION

BleepingComputer, Check Point links VPN zero-day attacks to Qilin ransomware gang <<https://www.bleepingcomputer.com/news/security/check-point-links-vpn-zero-day-attacks-to-qilin-ransomware-gang/>>

juin 2026

EXPLICATION

IT Social, Check Point corrige une faille critique d'accès distant sur ses passerelles VPN <<https://itsocial.fr/cybersecurite/cybersecurite-actualites/check-point-corrige-une-faille-critique-dacces-distant-vpn-exploitee-par-le-rancongiel-qilin-sur-ses-passerelles-vpn/>>

16 juin 2026

ANALYSE TECHNIQUE

Unit 42, Threat Brief: Active Exploitation of PAN-OS CVE-2026-0257 <<https://unit42.paloaltonetworks.com/active-exploitation-of-pan-os-cve-2026-0257/>>

9 juin 2026

ANALYSE TECHNIQUE

Arctic Wolf, Cookie Crumbles: How Exploitation of CVE-2026-0257 Leads to Qilin Ransomware <<https://arcticwolf.com/resources/blog/exploitation-of-cve-2026-0257-leads-to-qilin-ransomware/>>

juillet 2026

CVE-2026-50751

CVSS 9.3

- CVE-2026-50751, CVSS 9.3 : défaut de validation des certificats lors de l'échange de clés IKEv1. Un attaquant non authentifié peut établir une session VPN sans mot de passe valide
- Exploitable seulement si quatre conditions sont réunies : accès distant VPN activé, IKEv1 (protocole déprécié) encore actif, anciens clients acceptés, certificat machine non obligatoire
- Divulgation et correctif le 8 juin 2026 ; exploitation depuis le 7 mai, soit 32 jours ; quelques dizaines d'organisations touchées, dont un cas relié à un affilié du rançongiciel Qilin
- Ajout au catalogue KEV le 8 juin, correction exigée pour le 11 juin
- Versions concernées : de R80.20 à R82.10, dont plusieurs ne sont plus maintenues

- La faille ne donne que l'accès initial : selon Check Point, une action supplémentaire reste nécessaire pour atteindre les ressources internes
- Mesures de contournement données par l'éditeur : n'autoriser que IKEv2, retirer la prise en charge des anciens clients, rendre le certificat machine obligatoire
- Sur la faille Palo Alto de mai, Unit 42 indique le 9 juin que seule une petite partie des équipements sondés a réellement ouvert une session VPN ; Arctic Wolf documente pourtant, sur le même mois, plusieurs intrusions passées par cette faille et terminées par un déploiement de Qilin

Mon analyse. C'est le cas le plus riche de la période, pour trois raisons.

- La cause est une configuration héritée. IKEv1 est déprécié depuis des années. La faille n'est exploitable que si on l'a laissé actif, typiquement pour ne pas casser un vieux client. C'est la dette technique qui ouvre la porte.
- La chaîne est complète : équipement de bordure → accès initial → rançongiciel, et elle se répète chez deux éditeurs différents. On voit comment une faille réseau devient une crise d'entreprise.
- Le délai : 32 jours pendant lesquels des organisations étaient compromises sans le savoir.

Lien avec le BTS SIO SISR : VPN, IPsec et IKE, validation de certificats (PKI), et la règle « désactiver ce qui n'est pas utilisé » pour réduire la surface d'attaque.

ANALYSE TECHNIQUE

Unit 42, Threat Brief: Exploitation of PAN-OS Captive Portal Zero-Day for Unauthenticated Remote Code Execution <<https://unit42.paloaltonetworks.com/captive-portal-zero-day/>>

6 mai 2026

ANALYSE TECHNIQUE

Rapid7, Rapid7 Observed Exploitation of PAN-OS GlobalProtect Authentication Bypass Vulnerability (CVE-2026-0257) <<https://www.rapid7.com/blog/post/etr-rapid7-observed-exploitation-of-pan-os-globalprotect-authentication-bypass-vulnerability-cve-2026-0257/>>

29 mai 2026

EXPLICATION

The Hacker News, PAN-OS GlobalProtect Authentication Bypass (CVE-2026-0257) Under Active Exploitation <<https://thehackernews.com/2026/05/pan-os-globalprotect-authentication.html>>

30 mai 2026

DATATION

CERT-FR, CERTFR-2026-ALE-005 — Vulnérabilité dans Microsoft Exchange Server <<https://www.cert.ssi.gouv.fr/alerte/CERTFR-2026-ALE-005/>>

15 mai 2026

CVE-2026-0257

CVE-2026-0300

CVE-2026-42897

CVSS 7.8

- Dès le 6 mai, Unit 42 documente l'exploitation d'un zero-day dans le portail captif de PAN-OS (CVE-2026-0300), qui permet une exécution de code sans authentification
- CVE-2026-0257 : contournement d'authentification du portail et de la passerelle VPN GlobalProtect. Un cookie d'authentification forgé permet d'ouvrir une session VPN sans identifiants, dans une configuration précise (cookies de réauthentification activés et certificat réutilisé)
- Avis de l'éditeur le 13 mai 2026, avec une note de 4.7 (gravité moyenne) ; première exploitation observée le 17 mai
- Le 29 mai : Rapid7 publie son analyse et une preuve de concept, la note est relevée à 7.8 et la faille entre au catalogue KEV (échéance au 1^{er} juin)
- En parallèle, alerte du CERT-FR le 15 mai sur Microsoft Exchange Server (CVE-2026-42897) : les correctifs n'arrivent que le 9 juin

Mon analyse. La leçon du mois est que le score CVSS ne suffit pas à fixer les priorités. Notée 4.7, cette faille aurait été repoussée à la prochaine fenêtre de

maintenance dans beaucoup d'organisations ; elle a été exploitée quatre jours après sa publication. Sur un équipement exposé, le bon critère est ce que la faille permet : ici, entrer dans le réseau par le VPN. Avec le zero-day du portail captif, c'est aussi la deuxième faille exploitée sur le même système en un mois. Quant à Exchange, il rappelle qu'un serveur de messagerie publié sur Internet est lui aussi un équipement de bordure, avec un accès à l'annuaire interne.

Lien avec le BTS SIO SISR : priorisation des correctifs, gestion des certificats, journaux d'authentification VPN.

DATATION

CERT-FR, *CERTFR-2026-AVI-0400 — Vulnérabilité dans Fortinet FortiClientEMS* <<https://www.cert.ssi.gouv.fr/avis/CERTFR-2026-AVI-0400/>>

7 avril 2026

EXPLICATION

The Hacker News, Fortinet Patches Actively Exploited CVE-2026-35616 in FortiClient EMS <<https://thehackernews.com/2026/04/fortinet-patches-actively-exploited-cve.html>>

avril 2026

CVE-2026-35616

CVSS 9.1

- CVE-2026-35616 (CVSS 9.1) : contrôle d'accès défaillant dans l'API de FortiClient EMS → exécution de code ou de commandes sans authentification
- Correctif d'urgence publié un samedi, le 4 avril 2026 ; des tentatives d'exploitation sont relevées dès le 31 mars
- Ajout au catalogue KEV le 6 avril, correction exigée pour le 9 avril
- Le 8 avril, la seconde faille Ivanti de janvier (CVE-2026-1340) rejoint à son tour le catalogue KEV

Mon analyse. FortiClient EMS est le serveur qui administre les postes équipés du client d'accès distant. La cible se déplace d'un cran : au lieu d'attaquer la passerelle, on attaque l'outil qui gère tous ceux qui s'y connectent. La date compte aussi : un correctif publié un samedi suppose qu'une organisation sache traiter une urgence hors des heures ouvrées.

Lien avec le BTS SIO SISR : gestion de parc, serveurs d'administration, procédure de correctif d'urgence.

DATATION

CERT-FR, *CERTFR-2026-ALE-004 — Vulnérabilité dans F5 BIG-IP Access Policy Manager* <<https://www.cert.ssi.gouv.fr/alerte/CERTFR-2026-ALE-004/>>

31 mars 2026

RÉFÉRENCE

ANSSI / CERT-FR, *Panorama de la cybermenace 2025 (CERTFR-2026-CTI-002)* <<https://www.cert.ssi.gouv.fr/cti/CERTFR-2026-CTI-002/>>

11 mars 2026

CVE-2025-53521

- CVE-2025-53521 : exécution de code à distance sans authentification sur BIG-IP APM, le module d'accès distant de F5
- Correctif disponible depuis le 15 octobre 2025 ; F5 confirme l'exploitation active le 29 mars 2026
- Le CERT-FR recommande une recherche de compromission à partir d'indicateurs dans les fichiers et dans les journaux
- Le 11 mars, l'ANSSI publie son panorama annuel : les vulnérabilités des équipements de bordure y sont décrites comme pouvant être exploitées très vite

Mon analyse. C'est le premier cas « à l'envers » de la période : pas un zero-day, mais une faille dont le correctif existait depuis cinq mois et demi. Les organisations touchées n'ont pas été prises de vitesse, elles n'avaient pas appliqué la mise à jour. Le problème n'est donc pas seulement la rapidité des attaquants, c'est aussi la lenteur des mises à jour sur des équipements qu'on hésite à redémarrer.

Lien avec le BTS SIO SISR : gestion des correctifs, analyse des journaux, recherche d'indicateurs de compromission.

DATATION

CERT-FR, *CERTFR-2026-ALE-002 — Vulnérabilité dans Cisco Catalyst SD-WAN* <<https://www.cert.ssi.gouv.fr/alerte/CERTFR-2026-ALE-002/>>

25 février 2026

EXPLICATION

BleepingComputer, *Critical Cisco SD-WAN bug exploited in zero-day attacks since 2023* <<https://www.bleepingcomputer.com/news/security/critical-cisco-sd-wan-bug-exploited-in-zero-day-attacks-since-2023/>>

février 2026

EXPLICATION

BleepingComputer, *CISA orders federal agencies to replace end-of-life edge devices* <<https://www.bleepingcomputer.com/news/security/cisa-orders-federal-agencies-to-replace-end-of-life-edge-devices/>>

6 février 2026

CVE-2026-20127

CVSS 10

- CVE-2026-20127, CVSS 10.0 : contournement de l'authentification entre les composants du SD-WAN (contrôleur et gestionnaire) → accès administrateur sans authentification
- Exploitée depuis 2023 : l'attaquant ajoute de faux équipements « pairs » au réseau SD-WAN de la victime
- Le 25 février, la CISA publie une directive d'urgence et exige les correctifs pour le 27 février, soit 2 jours
- Le 5 février 2026, la CISA impose aux agences fédérales américaines de retirer les équipements de bordure en fin de support (directive BOD 26-02, détaillée en perspectives)

Mon analyse. Le SD-WAN pilote l'interconnexion des sites d'une entreprise : compromettre son contrôleur, c'est potentiellement agir sur tout le réseau étendu d'un coup. Le chiffre qui frappe est la durée : près de trois ans d'exploitation avant la divulgation. Et l'attaquant ne casse rien, il s'ajoute comme un équipement légitime : sans journaux conservés ailleurs que sur l'équipement, il est très difficile à repérer.

Lien avec le BTS SIO SISR : routage, interconnexion de sites, politique de filtrage, centralisation des journaux.

DATATION

CERT-FR, *CERTFR-2026-ALE-001 — Multiples vulnérabilités dans Ivanti Endpoint Manager Mobile* <<https://www.cert.ssi.gouv.fr/alerte/CERTFR-2026-ALE-001/>>

30 janvier 2026

ANALYSE TECHNIQUE

Rapid7, *Critical Ivanti Endpoint Manager Mobile (EPMM) zero-day exploited in the wild* <<https://www.rapid7.com/blog/post/etr-critical-ivanti-endpoint-manager-mobile-epmm-zero-day-exploited-in-the-wild-eitw-cve-2026-1281-1340/>>

30 janvier 2026

ANALYSE TECHNIQUE

Unit 42, *Critical Vulnerabilities in Ivanti EPMM Exploited* <<https://unit42.paloaltonetworks.com/ivanti-cve-2026-1281-cve-2026-1340/>>

17 février 2026

CVE-2026-1281

CVE-2026-1340

CVSS 9.8

- CVE-2026-1281 et CVE-2026-1340, toutes deux notées 9.8 CVSS : injection de code → exécution de code à distance sans authentification
- Divulguées le 29 janvier 2026, alors que l'exploitation a déjà commencé : c'est un zero-day
- Fonctions touchées : « In-House Application Distribution » et « Android File Transfer Configuration »
- CVE-2026-1281 ajoutée au catalogue KEV le jour même, avec une échéance au 1^{er} février : 3 jours, contre trois semaines habituellement
- À la divulgation, Ivanti ne propose qu'un correctif provisoire ; la version corrigée définitive est annoncée pour plus tard dans le trimestre
- Le 17 février, Unit 42 documente à son tour l'exploitation de ces deux failles : les attaques se poursuivent plus de deux semaines après la divulgation

Mon analyse. Trois enseignements. D'abord, zero-day veut dire que la chronologie normale est inversée : l'attaque précède le correctif, et « appliquer les mises à jour » ne suffit plus comme politique. Ensuite, le délai de 3 jours imposé par la CISA donne la mesure de l'urgence : on n'est plus dans la maintenance planifiée. Enfin, EPMM n'est pas un pare-feu mais un serveur de

gestion des terminaux mobiles publié sur Internet : la bordure se définit par l'exposition, pas par la catégorie de produit.

Lien avec le BTS SIO SISR : gestion du patrimoine informatique, maintenance préventive, et la question très concrète « combien de temps me faut-il pour corriger un équipement exposé ? ».

DATATION

CERT Santé, *WatchGuard Firebox – CVE-2025-14733* <<https://cyberveille.esante.gouv.fr/alertes/watchguard-firebox-cve-2025-14733-2025-12-19>>

19 décembre 2025

EXPLICATION

The Hacker News, *WatchGuard Warns of Active Exploitation of Critical Fireware OS VPN Vulnerability* <<https://thehackernews.com/2025/12/watchguard-warns-of-active-exploitation.html>>

19 décembre 2025

EXPLICATION

BleepingComputer, *Critical RCE flaw impacts over 115,000 WatchGuard firewalls* <<https://www.bleepingcomputer.com/news/security/over-115-000-watchguard-firewalls-vulnerable-to-ongoing-rce-attacks/>>

22 décembre 2025

CVE-2025-14733

CVSS 9.3

- CVE-2025-14733 (CVSS 9.3) : écriture hors limites dans le processus `iked`, qui gère l'échange de clés IKEv2 des pare-feu Firebox → exécution de code à distance sans authentification
- Correctifs publiés le 18 décembre 2025, alors que la faille est déjà exploitée
- Configurations concernées : VPN mobile IKEv2 et VPN site à site IKEv2 vers une passerelle à adresse dynamique
- Ajout au catalogue KEV de la CISA le 19 décembre, correction exigée pour le 26 décembre
- Le 22 décembre, plus de 115 000 pare-feu Firebox exposés sur Internet ne sont toujours pas corrigés

Mon analyse. La période s'ouvre sur ce qui sera son fil rouge : c'est le service VPN lui-même, censé sécuriser l'accès, qui sert de point d'entrée. Un détail de l'avis mérite d'être retenu : un pare-feu dont on a supprimé la configuration IKEv2 concernée peut rester vulnérable s'il conserve un VPN site à site. On ne peut donc pas se rassurer en relisant sa configuration ; seul le correctif règle le problème.

Lien avec le BTS SIO SISR : VPN IPsec et IKEv2, mise à jour des pare-feu, inventaire des équipements exposés.

Évolution sur la période

En 11 mois, j’ai relevé **15 cas** d’exploitation d’équipements d’accès distant, chez **9 éditeurs**. Quatre constats s’en dégagent.

1. L’attaque précède le plus souvent le correctif

Dans **11 cas sur 15**, la faille était exploitée avant la publication du correctif ou au moment de celle-ci. Le modèle classique « un correctif paraît, je l’applique à la prochaine fenêtre de maintenance » ne tient plus pour les équipements exposés. Lorsque la date de première exploitation est connue, l’écart est le suivant :

CAS	PREMIÈRE EXPLOITATION CONNUE	DIVULGATION ET CORRECTIF	ÉCART
Cisco Catalyst SD-WAN	2023	25 février 2026	Près de 3 ans
Fortinet FortiClient EMS	31 mars 2026	4 avril 2026	4 jours
Check Point VPN	7 mai 2026	8 juin 2026	32 jours
SonicWall SMA 1000	22 juin 2026	14 juillet 2026	22 jours
Citrix NetScaler	Début septembre 2026	27 septembre 2026	3 semaines au moins

Ces écarts vont de quelques jours à plusieurs années et ce sont des minimums, puisqu’ils reposent sur la première trace retrouvée. Je n’y vois pas de tendance à la baisse. Conclusion opérationnelle : on ne peut pas fonder sa défense sur la seule réactivité aux alertes. Il faut supposer la compromission possible et segmenter en conséquence.

2. Un correctif disponible ne protège que s'il est appliqué

Les **4 autres cas** sont l'inverse : le correctif existait, mais il n'avait pas été appliqué ou pas jugé prioritaire.

FAILLE	CORRECTIF	EXPLOITATION	CE QUI A MANQUÉ
F5 BIG-IP APM	15 octobre 2025	Confirmée le 29 mars 2026	L'application du correctif
Palo Alto GlobalProtect	13 mai 2026	Dès le 17 mai 2026	La priorité : faille notée « moyenne »
Citrix NetScaler	30 juin 2026	Mi-août 2026	La priorité : décrite comme déni de service
Check Point VPN	9 septembre 2026	Dès le 12 septembre 2026	Le temps : trois jours seulement

Dans deux cas sur quatre, c'est l'évaluation initiale de la gravité qui a trompé. Pour un équipement de bordure, la question à se poser n'est pas « quel est le score ? » mais « l'équipement est-il exposé, et que permet la faille ? ».

3. Les mêmes produits reviennent

Citrix NetScaler	Août 2026 · Septembre 2026 · Octobre 2026	×3
F5 BIG-IP APM	Mars 2026 · Septembre 2026	×2
Check Point VPN	Juin 2026 · Septembre 2026	×2
SonicWall SMA 1000	Juillet 2026 · Septembre 2026	×2

9 éditeurs différents, mais une seule fonction : le contrôle de l'accès distant. Ce n'est pas un problème de marque, c'est un problème structurel de la fonction elle-même : un service exposé à tous, qui traite des requêtes avant toute authentification et qui ouvre sur le réseau interne.

4. L'accès initial alimente l'extorsion

Les cas Check Point et Palo Alto le montrent : faille VPN → accès au réseau → rançongiciel Qilin. Check Point estime d'ailleurs que le même acteur exploite des

faillies VPN chez plusieurs éditeurs. L'équipement de bordure n'est pas la cible finale, c'est la porte d'entrée d'une chaîne qui se termine par le vol ou le chiffrement des données.

Perspectives à moyen terme

À horizon de deux à trois ans, trois évolutions me paraissent engagées.

1. Le cycle de vie des équipements devient une obligation

La directive BOD 26-02 de la CISA (5 février 2026) fixe aux agences fédérales américaines un calendrier de retrait des équipements de bordure qui ne reçoivent plus de mises à jour.

ÉCHÉANCE	OBLIGATION
5 mai 2026	Inventaire des équipements de bordure en fin de support
5 février 2027	Retrait des équipements déjà en fin de support
5 août 2027	Remplacement de tous les équipements identifiés
5 février 2028	Processus permanent de découverte et d'inventaire

Elle ne s'applique qu'à l'administration américaine, mais elle indique la direction : un inventaire tenu en continu et un remplacement planifié, au lieu d'équipements conservés tant qu'ils fonctionnent.

2. Du VPN au Zero Trust : une transformation progressive, pas un remplacement

RÉFÉRENCE	ANSSI, <i>Modèle Zero Trust – Les fondamentaux</i> < https://cyber.gouv.fr/sites/default/files/document/anssi-fondamentaux-zero-trust-v1.0.pdf > juin 2025
-----------	---

Le modèle Zero Trust vise à réduire la confiance implicite : chaque accès est contrôlé de façon fine et réévalué régulièrement, selon l'identité de l'utilisateur et l'état de son poste. L'ANSSI le présente comme une composante de la

défense en profondeur, à adopter de manière maîtrisée et progressive, et non comme un remplacement de la défense périmétrique.

MON ANALYSE

La chronologie montre pourquoi ce modèle progresse. Un VPN classique donne un accès large au réseau dès que le tunnel est établi : c'est ce qui rend si graves les contournements d'authentification de Check Point ou de Palo Alto. Le Zero Trust limite ce qu'une session permet, application par application, avec authentification multifacteur et contrôle de posture. Mais il ne supprime pas l'exposition : les briques sur lesquelles il repose sont elles-mêmes attaquées, comme le serveur de gestion des postes en avril ou le traitement SAML en octobre. Changer de technologie ne dispense ni des correctifs ni de la segmentation.

3. Corriger ne suffit plus : il faut savoir chercher une compromission

Sur la période, la CISA a presque toujours fixé des délais de deux à trois jours (Ivanti, Cisco, Fortinet, Palo Alto, Check Point, SonicWall, Citrix) là où la règle habituelle est de trois semaines. Et les éditeurs demandent de plus en plus souvent autre chose qu'une mise à jour : rechercher des indicateurs de compromission (F5), réinstaller le système et changer tous les secrets (SonicWall), renouveler des certificats dont la clé a pu être copiée (Citrix). Comme ces équipements échappent aux outils de détection des postes, leurs journaux, envoyés vers une plateforme externe, sont souvent la seule trace. Lire des indicateurs, analyser des journaux et renouveler des secrets deviennent des compétences attendues d'un administrateur, et plus seulement d'un spécialiste.

Synthèse et apports

Sur 11 mois, les équipements chargés de protéger l'accès au réseau ont été attaqués chaque mois, le plus souvent par des failles exploitées avant leur correctif et parfois pendant des semaines sans être détectées. Une frontière

seule ne suffit donc plus : il faut corriger en urgence, segmenter l'intérieur et vérifier chaque accès.

Quatre conséquences pratiques pour un administrateur SISR

1. **Inventorier l'exposition.** Savoir précisément ce qui est joignable depuis Internet. On ne protège pas ce qu'on ignore posséder.
2. **Traiter les correctifs de bordure comme une procédure d'urgence distincte**, avec un délai cible en heures ou en jours, pas en semaines, et sans se fier au seul score de gravité.
3. **Désactiver ce qui ne sert pas.** Le cas Check Point tient entièrement à un protocole déprécié resté actif.
4. **Segmenter l'intérieur.** Puisque la bordure finira par céder, il faut que la compromettre ne donne pas accès à tout : VLAN, ACL, moindre privilège, flux d'annuaire chiffrés.

Ce que cette veille m'a apporté

- Une méthode de recherche d'information : croiser une source officielle et une analyse technique, dater sur la première version, distinguer le fait de son commentaire.
- Un approfondissement technique de notions du programme : IPsec et IKE, certificats, SAML, filtrage, journalisation.
- Un changement de pratique : quand je configure un pare-feu ou une ACL, je désactive ce qui ne sert pas et je segmente en supposant que la bordure cédera.
- Une confirmation de mon projet professionnel, orienté vers la sécurité des infrastructures et du cloud.

Glossaire

35 termes, regroupés par thème.

Exposition

Équipement de bordure

Équipement à la frontière entre réseau interne et Internet : pare-feu, routeur, concentrateur VPN, passerelle d'accès.
Exposé par nature.

Surface d'attaque

Ensemble des points par lesquels un attaquant peut tenter d'entrer. La réduire, c'est fermer, désactiver, masquer.

Exposition

Fait d'être joignable depuis Internet.

Vulnérabilités et gravité

CVE

Identifiant mondial unique d'une vulnérabilité (CVE-ANNÉE-NUMÉRO).

CVSS

Score de gravité de 0 à 10 ; « critique » à partir de 9. Il mesure la gravité théorique, pas l'urgence réelle.

Zero-day

Vulnérabilité exploitée avant qu'un correctif n'existe.

Exploitation active

Des attaques réelles utilisant la faille sont observées (in the wild).

Preuve de concept

Code public démontrant qu'une faille est exploitable. Sa publication accélère les attaques.

Autorités et publications

Avis (CERT-FR)

Signale des vulnérabilités et leurs correctifs. Plus d'un millier par an.

Alerte (CERT-FR)

Niveau supérieur : faille jugée particulièrement grave, souvent déjà exploitée. Dix à quinze par an.

KEV (CISA)

Known Exploited Vulnerabilities : catalogue officiel américain des vulnérabilités exploitées, avec date d'ajout et échéance de correction imposée aux agences fédérales.

CERT-FR

Centre gouvernemental français de veille, d'alerte et de réponse aux attaques informatiques, rattaché à l'ANSSI.

ANSSI

Agence nationale de la sécurité des systèmes d'information.

CISA

Agence américaine de cybersécurité, éditrice du catalogue KEV.

Techniques d'attaque

RCE

Remote Code Execution : exécution de code à distance. L'un des impacts les plus graves.

SSRF

Server-Side Request Forgery : on fait émettre au serveur des requêtes qu'il est seul autorisé à faire, pour atteindre des services internes.

Dépassement mémoire

Écriture au-delà de la zone mémoire prévue. Peut faire planter le service ou permettre d'exécuter du code.

Traversée de répertoire

Utiliser ../ pour sortir du dossier autorisé et atteindre d'autres fichiers.

Identifiants codés en dur

Comptes et mots de passe inscrits dans le produit, identiques chez tous les clients.

Webshell

Script déposé sur un serveur compromis, offrant un accès à distance par requêtes web.

Mouvement latéral

Déplacement d'une machine compromise vers d'autres, à l'intérieur du réseau.

Déni de service

Attaque qui rend un service indisponible.

Rançongiciel

Maliciel qui chiffre ou vole les données contre rançon. Qilin en est un exemple actif sur la période.

Accès distant

VPN

Tunnel chiffré entre un poste distant et le réseau d'entreprise (IPsec ou SSL/TLS).

IKE (IKEv1, IKEv2)

Protocole d'échange de clés d'IPsec. IKEv1 est déprécié : le laisser actif est une dette technique.

Passerelle d'accès

Équipement qui authentifie et filtre les accès distants (SonicWall SMA, F5 BIG-IP APM, Citrix NetScaler Gateway).

SAML

Protocole d'authentification fédérée, base de l'authentification unique (SSO).

SD-WAN

Pilotage logiciel de l'interconnexion des sites d'une entreprise.

Défense

Zero Trust

Modèle qui réduit la confiance implicite : chaque accès est vérifié, même depuis l'intérieur. Complète la défense périmétrique sans la remplacer.

MFA

Authentification multifacteur : mot de passe plus code ou clé physique.

Contrôle de posture

Vérification de l'état du poste (correctifs, antivirus, chiffrement) avant d'autoriser la connexion.

Segmentation

Découpage du réseau pour limiter la propagation. VLAN et ACL en sont les outils de base.

Moindre privilège

Chaque compte n'a que les droits strictement nécessaires.

EDR

Endpoint Detection and Response : agent de détection installé sur les postes et les serveurs. Ne peut pas être installé sur une passerelle.

Indicateur de compromission

Trace (fichier, ligne de journal, adresse IP) permettant de vérifier si un équipement a été attaqué.
